

Security+ 2.5 · Hardening Techniques

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.5** —
Hardening Techniques (12:11) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Hardening minimizes the attack surface by removing unnecessary services, ports, and software (bloatware), changing default credentials, disabling unused accounts, applying patches, enforcing MFA, using application allowlisting, disabling USB autorun, setting BIOS/UEFI passwords, and disabling USB boot. The goal is to reduce the number of potential entry points an attacker can exploit.

High-Yield Core Concepts Tested on Exam

- Attack surface = everything that can be attacked — MINIMIZE it
- CIS benchmarks = industry-standard hardening checklists per platform
- Never use default accounts; disable unused ports and services
- Patch management, MFA, and application allowlisting are core hardening controls
- Disable USB autorun and USB boot; set BIOS/UEFI passwords to prevent physical attacks

Exam Tips & Classic Scenarios

- 'reduces the attack surface of a system' = hardening
- 'checklist of security configuration per platform' = CIS benchmark
- 'disable default accounts and unnecessary services' = hardening best practice

Typical Exam Scenario: A new server is deployed with only required ports open, minimal services running, default passwords changed, and automatic patching enabled. This is an example of hardening.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.5 — Hardening Techniques)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An isolated subnet that exposes public servers (web/email) while protecting the internal network is a:

- A)** Voice VLAN
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

3. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Attack surface = everything that can be attacked — MINIMIZE'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Attack surface = everything that can be attacked — MINIMIZE...

4. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'CIS benchmarks = the hardening checklist per platform (industry standard)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: CIS benchmarks = the hardening checklist per platform (industry standard)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Do NOT use the default account; disable unused ports/services.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Do NOT use the default account; disable unused ports/services...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'reduces the attack surface of a system' = hardening'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'reduces the attack surface of a system' = hardening...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'checklist of security configuration per platform' = CIS benchmark'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'checklist of security configuration per platform' = CIS benchmark...
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Scenario: new server joins the network with closed ports, minimal services, changed password, and automatic patching' = hardening (the default). What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: new server joins the network with closed ports, minimal services...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Attack surface = everything that can be attacked — MINIMIZE'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Attack surface = everything that can be attacked — MINIMIZE...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Hardening Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'CIS benchmarks = the hardening checklist per platform (industry standard)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: CIS benchmarks = the hardening checklist per platform (industry standard)...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — DMZ (screened subnet).

✓ **Why it's correct:** The correct answer is 'DMZ (screened subnet)'. A DMZ (Demilitarized Zone), also called a screened subnet, is an isolated network segment that sits between the trusted internal network and the untrusted external network (such as the Internet). It hosts public-facing servers, such as web, email, DNS, and FTP, which need to be accessible externally. The goal is that if one of these servers is compromised, the attacker does not have direct access to the internal network, because firewalls control traffic between the DMZ and the internal network. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.2), describes the DMZ as a security zone for exposing public services in a controlled manner. The question describes exactly this function: an isolated subnet that exposes public servers while protecting the internal network.

✗ **Why the others are wrong:**

- *Voice VLAN:* A voice VLAN is a virtual local area network dedicated to VoIP (Voice over IP) traffic, separating it from data to ensure quality of service (QoS) and security. It is not designed to expose public servers to the Internet; on the contrary, it isolates voice traffic. It does not provide the isolation between internal and external networks that a DMZ provides. Therefore, it does not meet the requirement of protecting the internal network while exposing public services.
- *VPN:* A VPN (Virtual Private Network) is a technology that creates an encrypted tunnel to transmit data securely over untrusted networks, enabling remote access or branch interconnection. Although it improves communication security, it is not an isolated subnet for hosting public servers. A VPN can be used to access the DMZ, but it does not replace the DMZ. The question asks for a network zone that exposes public servers, which is not the primary function of a VPN.
- *Intranet:* An intranet is a private internal network that uses Internet technologies (such as HTTP, FTP) to share information within an organization. It is accessible only to authorized users and is not exposed to the external public. Therefore, it is not used to host public servers that need to be accessed from the Internet. The intranet is the opposite of a DMZ in this respect: it is internal and restricted, not a controlled exposure zone.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST

CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) D — Implement the corresponding solution: Attack surface = everything that can be attacked — MINIMIZE....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): Attack surface = everything that can be attacked — MINIMIZE.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

4) B — Implement the corresponding solution: CIS benchmarks = the hardening checklist per platform (industry standard)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): CIS benchmarks = the hardening checklist per platform (industry standard). CIS Benchmarks are consensus-based, platform-specific configuration guidelines developed by the Center for Internet Security to securely configure operating systems, applications, and network devices.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: Do NOT use the default account; disable unused ports/services....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): System hardening includes changing default credentials, disabling unnecessary services and ports, and removing default accounts to reduce the attack

surface. These are essential preventive measures.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'reduces the attack surface of a system' = hardening....

✓ Why it is correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): 'reduces the attack surface of a system' = hardening.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) C — Implement the corresponding solution: 'checklist of security configuration per platform' = CIS benchmark....

✓ Why it is correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): 'checklist of security configuration per platform' = CIS benchmark. CIS benchmarks provide prescriptive configuration guidelines for securely hardening various platforms.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: Scenario: new server joins the network with closed ports, minimal services....

✓ Why it is correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): Scenario: new server joins the network with closed ports,

minimal services, changed password, and automatic patching = hardening (the default). Hardening reduces the attack surface by eliminating unnecessary services, closing unused ports, enforcing strong credentials, and ensuring timely patching.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Attack surface = everything that can be attacked — MINIMIZE....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): Attack surface = everything that can be attacked — MINIMIZE. Reducing the attack surface involves removing unnecessary services, closing unused ports, and applying the principle of least functionality to limit potential entry points for attackers.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: CIS benchmarks = the hardening checklist per platform (industry standard)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Hardening Techniques): CIS benchmarks = the hardening checklist per platform (industry standard). CIS (Center for Internet Security) benchmarks provide prescriptive, consensus-based configuration guidelines to securely harden operating systems, applications, and network devices.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.